



Vulnerability Management Process

Approved : RCC

Prepared by : VP Infosec

Last reviewed : March 2025

Next review : March 2026

Purpose

Lean's Vulnerability Management process describes what systems are in place to monitor for new vulnerabilities, how often vulnerabilities are addressed, and the way in which those vulnerabilities are addressed.

In nutshell this describes below things

- a. all information assets;
- b. Frequency of performing the vulnerability scan (risk-based);
- c. Classification of vulnerabilities;
- d. Defined timelines to mitigate (per classification);
- e. Prioritization for classified information assets;
- f. Patch management and method of deployment.

Lean information assets and classification

ID	Asset /component	Confidentiality Impact	Integrity Impact	Availability Impact
A1	LinkSDK APIs	Low/Medium	Medium	Medium (depends on how many end-user are affected)
A2	Lean BE	Critical	Critical	Critical
A3	TPP BE	Out of scope	Out of scope	Out of scope
A4	DevPortal	Critical	High	Medium
A5	Internal 3rd party tools	High	High	Medium
A6	Internal developed services (e.g. OTP)	Critical	High	Medium
A7	3rd party tools/services that are publicly exposed (Mix Panel, Segment, CDN buckets)	Medium	High	Medium

Below is the list of all assets which are in scope of Vulnerability management , this list is point in time taken from -

<https://docs.google.com/spreadsheets/d/1wHdaLreZY2ialjvhTa4AJ02Xe1L4sMJgvKPJVdJP5dk/edit?gid=93372284#gid=93372284> This list updates regularly based on requirement

Measuring and Evaluating the Effectiveness of the Vulnerability Management Process

The organization shall regularly measure and evaluate the effectiveness of its Vulnerability Management Process to ensure timely identification, prioritization, and remediation of security vulnerabilities.

Key Performance Indicators (KPIs) such as:

- # of vulnerabilities failing remediation Security Team SLAs – Measures the number of vulnerabilities that exceed defined remediation timelines, ensuring accountability in addressing security risks.
- # of reported vulnerability disclosures not known internally – Tracks externally reported vulnerabilities that were not previously identified by internal security processes, highlighting gaps in internal scanning and testing.
- # of infrastructure vulnerabilities identified and fixed by Infra VA – Evaluates the effectiveness of infrastructure vulnerability assessments (VA) by tracking the number of detected and successfully remediated vulnerabilities.
- # of Insider Threat Incidents – Monitors vulnerabilities and security weaknesses exploited by internal actors, ensuring that insider threats are addressed as part of the vulnerability management process.

- # of identified security vulnerabilities from 3rd party penetration testing – Assesses the effectiveness of security controls based on vulnerabilities discovered by external penetration testers.
- # of identified security vulnerabilities from internal testing – Measures vulnerabilities detected through internal security assessments, red teaming, and continuous security testing.
- Automated and manual vulnerability scans shall be conducted on a regular basis to assess infrastructure, applications, and cloud environments.
- Findings from penetration tests, threat intelligence feeds, and incident investigations shall be analyzed to improve the vulnerability management lifecycle.

This ensures a proactive, risk-based approach to vulnerability management, reducing the organization's exposure to security threats.

Frequency of performing the vulnerability scan (risk-based)

As an integral component of our robust vulnerability management framework, we conduct regular security assessments to ensure the resilience and compliance of our critical environments.

Specifically:

- At infrastructure level
 - We adhere to a rigorous schedule of Tenable Nessus scans for both our production (KSA Prod) and sandbox environments on a weekly. These scans leverage the latest risk-based methodologies to comprehensively assess and quantify vulnerabilities, thereby enabling us to prioritize and address critical issues effectively.
 - We utilize Oracle Cloud Guard services to identify vulnerabilities and misconfigurations through the services internal scanning. We review the Cloud Guard findings on a weekly basis
 - We employ manual infrastructure penetration testing activities to supplement the use of the automatic tools
- At application level
 - We use Burp Suite Pro tool for automatic security testing as well as for API level security testing
 - We use Snyk and SonarQube tools for SAST and SCA
 - We employ manual penetration testing activities to supplement the use of the tool

In addition to our by-monthly security scans, we perform the additional security activities:

- By-yearly 3rd party penetration testing (both infrastructure and application level)
- security regression testing
- Daily functional testing (QA) that also covers security test cases

Notes :

- Vulnerabilities reported by Nessus are rescored/re-casted if needed as usually Nessus tenable does not take into account the exploitability part of the vulnerabilities but mainly the CVSS.
- DevOps team has a monthly slot scheduled to address vulnerabilities and perform patches raised by Nessus (unless the vulnerability raised on a weekly basis is indeed High or Critical. In this scenario, the below SLA will apply)

By diligently performing security scans on a scheduled basis, we bolster our proactive approach to identifying and mitigating vulnerabilities, ultimately enhancing the security posture of our environments while meeting the stringent regulatory obligations imposed by SAMA. This comprehensive vulnerability management strategy serves as an integral element in safeguarding our infrastructure, data, and reputation against emerging threats and vulnerabilities.

Triaging Vulnerabilities

We have staff consisting of developers, security, IT team with knowledge of cyber security risk, business risk. This group should be responsible for communicating weekly after vulnerability assessment have been performed in order to triage all vulnerabilities found.

Vulnerability assessment software will normally assign a severity rating to issues; this severity is considered as part of the process. The Common Vulnerability Scoring System (CVSS) assigns numeric scores to vulnerabilities and attempts to assist in the process of vulnerability triage.

Our triage process divides all issues identified into three categories: **Fix**, **Acknowledge/Risk accept** and **Investigate**.

- **Fix** issues are those for which a patch, re-configuration or mitigation will be put in place. These fixes should be prioritised and given a date by which the fix will be put in place.
- **Acknowledge/risk accept** issues are those which, for whatever reason, we decide **not** to resolve *at present*. There are valid reasons for not immediately resolving a vulnerability, and they should be recorded, along with the reasoning for acknowledging it and a review date given. If the level of risk they present is sufficiently high, record the issue in a risk register. The rationale for acknowledging an issue — and *not* fixing it — should be sufficient to justify the decision made should the vulnerability be exploited in future.
- **Investigating** issues should be used *only as a temporary status* where we are unable to categorise it as 'to **fix**' or 'to **acknowledge**'. This may be because the cost of resolving the issue is not known, or there are a number of possible resolutions and more work is required to identify which works best. Vulnerability assessment software is not infallible and false positives can occur. Where this is suspected then an investigation should be performed before removing the issue. Timescales for issues in this category will depend on the likely severity of the issue.

Severity & Timing

Lean defines the severity of an issue via industry-recognized [Common Vulnerability Scoring System 3.1](#) (CVSS) scores, which all modern scanning and continuous monitoring systems utilise.

The CVSS provides a way to capture the characteristics of a vulnerability and produce a numerical score reflecting its severity. The numerical score can then be translated into a qualitative representation (such as low, medium, high, and critical) to help organizations properly assess and prioritise their vulnerability management processes.

All vulnerabilities will be addressed within reasonable timelines as defined by company procedural commitments.

Classification of vulnerabilities

In our vulnerability management strategy, we have embraced the Common Vulnerability Scoring System (CVSS) 3.1 as the cornerstone for classifying vulnerabilities. Adopting the CVSS 3.1 scoring system allows us to maintain a standardized and objective approach to vulnerability assessment. By leveraging its comprehensive metrics and the inclusion of environmental factors, we can precisely evaluate the potential impact of vulnerabilities on our systems. This, in turn, empowers us to make informed decisions when prioritizing remediation efforts, ensuring that resources are allocated efficiently to address the most critical vulnerabilities first. CVSS 3.1's widespread industry acceptance and our integration of it into our processes reflect our commitment to a systematic and well-informed approach to vulnerability management.

Critical Severity - CVSS 9.0 - 10.0

Urgent (Critical) severity vulnerabilities likely lead to root level compromise of servers, applications, and other infrastructure components. If a critical vulnerability cannot be addressed within timelines as defined, an incident response ticket will be opened, documenting what interim remediation has been made.

SLA : Issue should be fixed *in less than 3 days time.*

High Severity - CVSS 7.0 - 8.9

High severity vulnerabilities are typically difficult to exploit but could result in escalated privileges, significant data loss, and/or downtime.

SLA : Issue should be fixed *in less than 4 weeks time.*

Medium Severity - CVSS 4.0 - 6.9

Medium severity vulnerabilities usually require the same local network or user privileges to be exploited.

SLA: Issue should be fixed *in less than 24 weeks time.*

Low Severity - CVSS 0.1 - 3.9

Low severity vulnerabilities are likely to have very little impact on the business, perhaps because they require local system access.

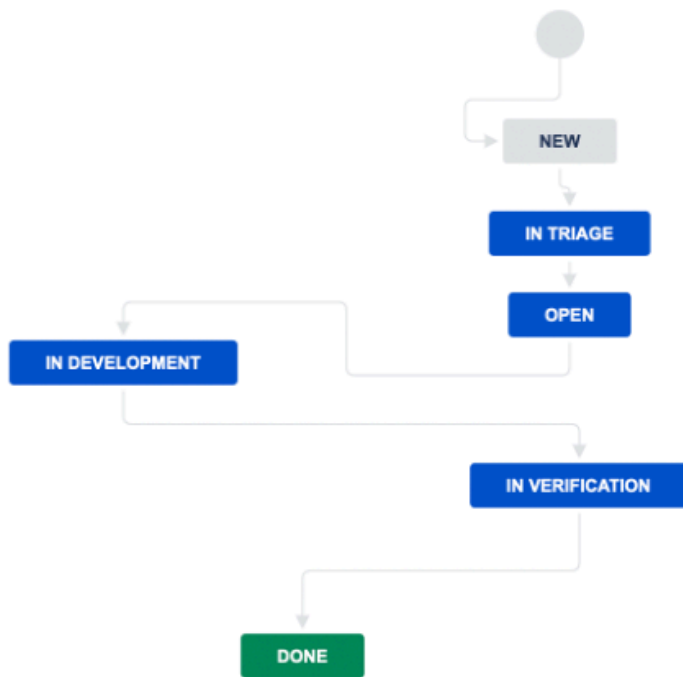
SLA : Issue should be fixed *in less than 48 month time*.

Note : Low severity vulnerabilities fall under Lean risk appetite, so they may be risk accepted.

Vulnerability & Patch Management Process

1. A new vulnerability or a new required patch is detected from the various monitoring and scanning activities Lean has in place.
2. Enter vulnerability details or patch instructions into Lean's change management system, and assigns the ticket to the appropriate team member to address.
3. The ticket assignee follows the change and release management process (see more details [here](#)) to implement the necessary change to apply the patch or address the new vulnerability.
4. The ticket is updated with results from the applied change, detailing any exceptions into the ticket log.
5. Perform security testing to ensure that the change performed has addressed the vulnerability detected.

JIRA Workflow



VM Status flow:

- New –When Security Vulnerability type is created in JIRA (by Product Security or Engineering team)
- In Triage – Moved my Head of Cyber Security to perform peer review
- Open – Moved by Head of Cyber Security and assigned to EM
- In Development – Moved by EM and assigned to engineer
- In Verification – Moved by engineer and assigned back to the penetration tester (Yash) for validation of the fix
- Done - Moved by penetration tester or Head of Cyber Security

Exceptions

Any exception to the policy must be approved by the Head of Security and CTO.



[How Vulnerability Management works in action at Lean](#)



[What is CVSS](#)



[CVE Identifiers](#)



[CVE Details](#)



[Vulnerability Database](#)